

[MITRE ATT&CK Framework - Security Operations Guide]

[What is MITRE ATT&CK Framework?]

The MITRE ATT&CK Framework is a globally used cybersecurity knowledge base that documents real-world attacker behavior. The framework is maintained by the MITRE Corporation.

"MITRE ATT&CK is a framework that maps how cyber attackers behave during attacks."

ATT&CK Stands For: Adversarial Tactics, Techniques, and Common Knowledge.

It helps security teams understand:

- How attackers operate
- Attack techniques
- Detection methods
- Defensive strategies

[Why MITRE ATT&CK is Important]

SOC analysts utilize this framework to detect cyber attacks, understand adversary behaviors, perform predictive threat hunting, design resilient SIEM detection use cases, improve incident response workflows, and map complex malware campaign activities.

[Core Concepts & Structural Hierarchy]

The matrix ecosystem is structured systematically into four layered dimensions:

```
[ MITRE ATT&CK Conceptual Hierarchy ]
└─ [ Tactic ] ──> The Attacker's Goal / Objective (Why?)
    └─ [ Technique ] ──> The Technical Method (How?)
        └─ [ Sub-Technique ] ──> Refined Sub-Method (Detailed Variant)
            └─ [ Procedure ] ──> Practical Implementation / Tool (Exact Step)
```

[Practical Hierarchical Mapping Example]

- **Tactic:** Credential Access
- **Technique:** Credential Dumping
- **Sub-Technique:** OS Credential Dumping (e.g., LSA Secrets parsing)
- **Procedure:** Threat actor running the Mimikatz tool to dump Windows cleartext credentials from LSASS memory.

[1. Framework Tactics Breakdown]

Tactics represent the high-level operational objective an attacker wishes to accomplish across the lifecycle of a breach.

Tactic Name	Purpose & Attacker Operational Target
Reconnaissance	Gathering information about the target network or infrastructure.
Resource Development	Preparing malicious infrastructure, domains, accounts, or malware tools.
Initial Access	Methods utilized to gain an entry point into the target system boundaries.
Execution	Running malicious shellcode, scripts, or operational commands on systems.
Persistence	Establishing persistent footprints to maintain network access over reboots.
Privilege Escalation	Exploiting vulnerabilities or flaws to gain system admin or root privileges.
Defense Evasion	Avoiding live endpoint monitoring filters and disabling security agents.
Credential Access	Stealing account usernames, hashes, and authentication tokens.
Discovery	Collecting detailed environment asset listings and folder configuration layouts.
Lateral Movement	Pivoting away from compromised hosts to traverse across internal network nodes.
Collection	Aggregating targeted confidential databases and files into unified locations.
Command and Control	Initiating interactive remote session channels back to host infrastructure servers.
Exfiltration	Stealing and compressing internal data arrays outside organizational networks.
Impact	Executing data destructive routines, locking up drives, or deploying ransomware.

[2. Techniques & MITRE Matrices]

Techniques expand explicitly on the technical implementation options open to attackers within an individual tactic category.

```
[ MITRE ATT&CK Environment Matrices ]
├─ 1. Enterprise Matrix  → (Covers: Windows, Linux, macOS, Cloud [Azure/AWS], AD, Containers)
├─ 2. Mobile Matrix      → (Covers: Vulnerabilities & Attacks on Android / iOS platforms)
└─ 3. ICS Matrix         → (Covers: Attack loops targeting Industrial Control Systems)
```

[Real-Life Incident Scenario Mapping]

- Administrative PowerShell modules execute highly encoded command parameters.

Real-World Activity Flow	Correlated MITRE ATT&CK Mapping
Attacker sends a spoofed vector email to an employee.	Initial Access (Phishing)
Employee opens attachment; malicious macro runs automatically.	Execution (Command & Scripting Interpreter)
Macro writes unauthorized run strings into the system hive.	Persistence (Registry Run Keys)
Malware extracts host passwords directly from internal cache memory.	Credential Access (Credential Dumping)
Execution (PowerShell Abuse)	
Confidential server databases are zipped and sent outside the company network.	Exfiltration (Exfiltration Over C2 Channel)

[Crucial Techniques & Technical Signatures inside the SOC]

[1. Phishing (T1566)]

- **Tactic Context:** Initial Access
- **Sub-Technique Profile:** Spearphishing Attachment
- **Defensive Focus:** Auditing anomalies inside secure email gateway parameters.

[2. PowerShell Abuse (T1059.001)]

- **Tactic Context:** Execution
- **Operational Forensic Sample:** powershell.exe -EncodedCommand <Base64_String>

[3. Credential Dumping (T1003)]

- **Tactic Context:** Credential Access
- **Common Exploitation Instrument:** Mimikatz framework.

[4. Registry Run Keys (T1547.001)]

- **Tactic Context:** Persistence
- **Anomalous Behavior:** Writing values into standard windows Startup folder paths or Run registry subkeys.

[5. Application Layer Protocol (T1071)]

- **Tactic Context:** Command and Control
- **Anomalous Behavior:** Standard systems initiating connections over uncommon ports or masking commands inside benign protocols.

[Threat Hunting & SIEM Rule Engineering]

SOC analysts leverage MITRE ATT&CK IDs (e.g., T1021 for Remote Services) to build fine-tuned analytics detection models rather than checking for isolated IoC indicators.

[Practical SIEM Detection Correlation]

```
[ Live SIEM Alert Event ] —> Log detects: [ powershell.exe downloading file from external source ]
|
|
```

▼
[Defensive Analytical Mapping] → T1059 (Command and Scripting Interpreter / PowerShell)

Threat Hunt Process Framework: Threat hunters actively check endpoint parameters for telemetry anomalies like administrative shell executions (`cmd.exe /c` or obfuscated `powershell.exe -enc`) to detect hidden **Execution** and **Defense Evasion** behaviors simultaneously.

[MITRE ATT&CK vs Cyber Kill Chain]

MITRE ATT&CK Matrix	Cyber Kill Chain Framework
Details granular, multi-dimensional adversary behaviors .	Maps broad, high-level sequential attack stages .
Contains hundreds of specific technical techniques & sub-techniques.	Consists of exactly 7 structural chronological phases.
Primarily utilized for deep detection engineering and hunting.	Primarily used to understand and break the generic threat lifecycle.
Requires advanced practice and continuous operational tracking.	Significantly easier to learn and map out initially.

[Framework Operations Evaluation]

[Advantages]

- Provides deep, data-driven insights sourced directly from real-world threat intelligence.
- Acts as the definitive industry-wide standard language for global security defense cells.
- Allows accurate mapping of behavioral coverage overlays inside the **ATT&CK Navigator** app.
- Dramatically accelerates baseline incident investigation accuracy.

[Limitations]

- Highly complex matrix structures that present a steep learning curve for beginner tier-1 analysts.
- Demands consistent tuning cycles because threat profiles update dynamically.

[Operational Tool Integration]

- **Splunk / Elastic SIEM / Microsoft Sentinel:** Native mapping of logging rules directly to ATT&CK tactics.
- **CrowdStrike / Microsoft Defender:** Correlating endpoint process alarms with technique codes automatically.

[Workflow Methodology inside the SOC]

```
[ Step 1: Alert Trigger ] → [ Step 2: Live Triage ] → [ Step 3: Map MITRE IDs ]
                                     |
                                     ▼
[ Post-Incident Review ] ← [ Step 5: Remediate ] ← [ Step 4: Trace Behavior ]
```

[Interview Preparation: Core Questions & Answers]

Q1. What is the MITRE ATT&CK Framework?

Answer: It is an industry-standard, globally accessible knowledge repository documenting real-world cyber adversary behavioral patterns, techniques, and operational tactics.

Q2. What does the ATT&CK acronym stand for?

Answer: It stands for Adversarial Tactics, Techniques, and Common Knowledge.

Q3. What do Tactics signify inside the MITRE framework?

Answer: Tactics detail the strategic goal or functional objective an attacker wants to execute at a specific step in an incident campaign (the "Why" of the execution loop).

Q4. Provide classic examples of explicit techniques documented in the matrix along with their IDs.

Answer: Core references include PowerShell execution (T1059.001), Phishing campaigns (T1566), and Credential Dumping actions (T1003).

Q5. Why is MITRE ATT&CK fundamentally vital for Tier-1 SOC operations?

Answer: It transforms triage processing away from chasing volatile, fragile static markers (like file hashes) towards identifying permanent behavioral paths, allowing analysts to accurately map defensive coverage gaps.